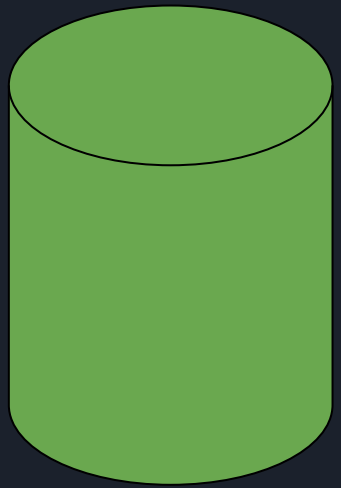
GESTIÓN DE DATOS

ADMINISTRACIÓN: PRIVILEGIOS

RECORDERIS...



¿QUÉ APRENDEREMOS HOY?



- Tipos de privilegios
- Alcance de cada privilegio
- Limitar recursos a usuarios y roles

PARA REFLEXIONAR...

¿Que pasa si un desarrollador novato tiene permisos para borrar cualquier cosa en la base de datos?

(discusión verbal)

¿Qué significa "PRIVILEGIO"



DEFINICIÓN: Privilegio

Define qué puede hacer o que no puede hacer un usuario en una base de datos

Usuario: quién se conecta (auth-n)
Privilegio: qué puede hacer una vez conectado (auth-z)

PRIVILEGIOS: ¿Para qué?

- Evita pérdida de datos por errores humanos
- Protegen el acceso a datos críticos o sensibles
- Separa responsabilidades
- Son una de las herramientas que posee el DBA para complementar la administración de los usuarios
- ***Ejemplo***: El desarrollador modifica estructura, el analista modifica datos

PRIVILEGIOS: Clases

Globales	`*.*`	`Instancia completa`
A nivel de base de datos	`world.*`	`Base de datos completa`
A nivel de rutinas	`world.fn_get_city` `world.pr_get_cities`	***`Rutinas`*** `específicas`
A nivel de tablas	`world.countries` `world.cities`	`Tablas específicas`
A nivel de columnas en tablas	`world.countries.name` `world.citiesy.name`	`Columnas específicas de tablas específicas`

PRIVILEGIOS: Analogía

Globales ⇒ Acceso a todo el edificio

Base de datos ⇒ Acceso a un piso

Tablas / rutinas ⇒ Acceso a una oficina

Columnas ⇒ Acceso a un escritorio de la oficina



PRIVILEGIOS: Clasificación

DML (Datos)

⇒ que operaciones de datos puedo hacer en una tabla

⇒ select, update, insert, delete

DDL (Estructura)

⇒ que cambios de estructura puedo hacer

⇒ create, alter, drop

DBA (Administración)

⇒ que permisos puedo asignar y a quien

⇒ grant, revoke

¿Que privilegios tiene mi instancia?

```
MariaDB [gd]> show privileges;
+-------------------------+-----------------------------------------+-----------------------------------------------------------------+
| Privilege               | Context                                 | Comment                                                         |
+-------------------------+-----------------------------------------+-----------------------------------------------------------------+
| Alter                   | Tables                                  | To alter the table                                              |
| Alter routine           | Functions,Procedures                    | To alter or drop stored functions/procedures                    |
| Create                  | Databases,Tables,Indexes                | To create new databases and tables                              |
| Create routine          | Databases                               | To use CREATE FUNCTION/PROCEDURE                                |
| Create temporary tables | Databases                               | To use CREATE TEMPORARY TABLE                                   |
| Create view             | Tables                                  | To create new views                                             |
| Create user             | Server Admin                            | To create new users                                             |
| Delete                  | Tables                                  | To delete existing rows                                         |
| Delete history          | Tables                                  | To delete versioning table historical rows                      |
| Drop                    | Databases,Tables                        | To drop databases, tables, and views                            |
| Event                   | Server Admin                            | To create, alter, drop and execute events                       |
| Execute                 | Functions,Procedures                    | To execute stored routines                                      |
| File                    | File access on server                   | To read and write files on the server                           |
| Grant option            | Databases,Tables,Functions,Procedures   | To give to other users those privileges you possess             |
| Index                   | Tables                                  | To create or drop indexes                                       |
| Insert                  | Tables                                  | To insert data into tables                                      |
| Lock tables             | Databases                               | To use LOCK TABLES (together with SELECT privilege)             |
| Process                 | Server Admin                            | To view the plain text of currently executing queries           |
| Proxy                   | Server Admin                            | To make proxy user possible                                     |
| References              | Databases,Tables                        | To have references on tables                                    |
| Reload                  | Server Admin                            | To reload or refresh tables, logs and privileges                |
```

PARA REFLEXIONAR (1)

¿Que puede hacer el usuario "test" después de la siguiente sentencia?

```
create user test@'%' identified by test;
```

(discusión verbal)

PARA REFLEXIONAR (2)

¿Qué sucede si el usuario "test" se loguea justo después del comando de la diapositiva anterior y ejecuta el siguiente comando (o si en Heidi/Workbench le da doble click a la base de datos "world")?

```
use world;
```

(discusión verbal)

PARA REFLEXIONAR (3)

Asumiendo que el usuario "test" pudo entrar a la base de datos world, ¿Qué sucede si ejecuta este comando?

```
select * from countries;
```

(discusión verbal)

PRIVILEGIOS: Asignación

👍	Permitir conexión y uso (comando "use") en una base de datos específica	`grant usage on world.* to selena;`
👎	Permitir conexión y uso en todas las bases de datos de toda la instancia (***no recomendado***)	`grant usage on *.* to selena;`

NOTA: Usuarios sin el privilegio "usage" podrán conectarse a una instancia pero no a una base de datos en MariaDB o MySQL

PRIVILEGIOS: Asignación

Permitir creación de rutinas (funciones y procedimientos) a un usuario en la base de datos world	`grant create routine on world.* to selena;`
Permitir modificación y borrado de rutinas	`grant alter routine on world.* to selena;`
Permitir creación de tablas, bases de datos e índices	`grant create on world.* to selena;`
Permitir borrado de tablas, bases de datos e índices	`grant drop on world.* to selena;`

PRIVILEGIOS: Asignación

Permitir consultar una tabla	`grant select on world.city to selena;`
Permitir insertar registros en una tabla	`grant insert on world.city to selena;`
Permitir las 4 operaciones usando una única sentencia	`grant insert, update, delete, select on world.city to selena;`
Permitir seleccionar ciertas columnas en una tabla	`grant select(Name, Code) on world.country;`

PARA REFLEXIONAR (1)

¿Estaría bien si un usuario con X permisos pudiera asignarle esos mismos permisos a otro usuario?

(discusión verbal)

PARA REFLEXIONAR (1)

¿Estaría bien si un usuario con acceso completo y sin restricciones pudiera darle acceso completo y sin restricciones a los usuarios que quiera?

(discusión verbal)

PRIVILEGIOS: Propagación

Permitir creación de tablas, y que el usuario pueda dar este privilegio a otros usuarios	`grant create on world.* to selena with grant option;`
Permitir consultar una tabla, y que el usuario pueda dar este privilegio a otros usuarios	`grant select on world.city to selena with grant option;`

NOTA: Tener cuidado sobre qué permisos se asignan con el "with grant option" para evitar puertas traseras y vulnerabilidades

PRIVILEGIOS: Propagación

Permitir todo lo que sea posible en una base de datos	`grant all privileges on world.* to selena;`
Permitir todo lo que sea posible en una instancia	`grant all privileges on *.* to selena;`
Permitir todo lo que sea posible, con opción de hacerlo a otros usuarios	`grant all privileges on *.* to selena with grant option;`

NOTA: Estas 3 son *ejemplos de lo que NO SE DEBE HACER*; se explican a modo ilustrativo y por conocimiento de su existencia, sin embargo son totalmente desaconsejadas por motivos de seguridad de los datos, en especial la tercera

PRIVILEGIOS: Propagación

¿Porqué evitar "all privileges" y "with grant option" cuando sea posible?

- Rompe con el principio del mínimo privilegio
- Dificulta la auditoria (quién hizo qué)
- Crea dependencias en cascada (MUY INSEGURO)

CONCLUSIÓN: ¿Es cómodo? Si. ¿Es seguro? No

¿LO SABÍAS?

Al igual que prestar la contraseña del usuario root, otra de las mejores formas de perder el control sobre la base de datos es darle a un usuario "all privileges", en especial con "with grant option".

Adicionalmente, otra de las mejores formas de perder el control sobre la base de datos es darle a un usuario "all privileges", en especial con "with grant option"..

Por último, por favor, recuerda que una de las mejores formas de perder el control sobre la base de datos es darle a un usuario "all privileges", en especial con "with grant option".

¿Está claro el mensaje?



IMPORTANTE!!!

Repite conmigo:

"NUNCA debería ejecutar el comando grant all privileges a un usuario regular, salvo que sea estrictamente necesario"

"Debo tener cuidado al usar with grant option para evitar propagación de permisos sin autorización"



PRIVILEGIOS: Eliminación

grant **asigna permisos**

revoke **quita lo que grant da**

PRIVILEGIOS: Eliminación

Impedir conexión a la base de datos y uso en toda la instancia	`revoke usage on *.* from selena;`
Impedir modificación y borrado de rutinas	`revoke alter routine on world.* from selena;`
Impedir creación de tablas, bases de datos e índices	`revoke create on world.* from selena;`
Impedir las 4 operaciones DML usando una única sentencia	`revoke insert, update, delete, select on world.city from selena;`
Impedir todo lo que sea posible	`revoke all privileges on *.* from selena;`

IMPORTANTE!!!

En versiones antiguas de MariaDB o MySQL, es posible que los cambios no se vean reflejados de forma inmediata.

Para solucionar esta situación, ejecutar el comando "flush privileges" después de aplicar grant o revoke.



PRIVILEGIOS: Roles

Asignar 2 usuarios a un rol. Darle permisos al rol. Los usuarios heredarán los permisos del rol (***Esta es la verdadera utilidad de los roles***)	`create role pop_singers;`
	`grant pop_singers to selena, ariana;`
	
	`grant select, insert, update on world.city to pop_singers;`

Asignar permisos a un rol con opción de propagación (***no recomendado***)	`grant select, update on world.city to pop_singers with grant option;`
Asignar permisos de modificar DDL a un rol (y por ende, a los usuarios que hacen parte de éste)	`grant create on world.* to pop_singers;`

PRIVILEGIOS: Roles

¿Por qué esta es la verdadera utilidad de los roles?

Varios usuarios con el mismo perfil y usando roles 😃	`grant pop_singers to selena, ariana, taylor;`
	`grant select on world.cities to pop_singers;`
	`grant update on world.countries to pop_singers;`
	
	`-- taylor cambia de rol (se saca de un rol y pasa a otro)`
	`revoke pop from taylor;`
	`grant rock to taylor;`

Varios usuarios con el mismo perfil y sin usar roles 😞	`grant select on world.cities to selena, ariana, taylor;`
	`grant update on world.countries to selena, ariana, taylor;`
	
	`-- taylor cambia de rol (modificar permisos uno por uno)`
	`revoke select on world.cities from taylor;`
	`revoke update on world.countries from taylor;`
	`grant select on world.languages to taylor;`
	`grant select on world.countries_languages to taylor;`

PRIVILEGIOS: Consulta

Consultar privilegios de un usuario o rol	`show grants for selena;` `show grants for pop_singers;`

```
MariaDB [gd]> show grants for selena;
+---------------------------------------------------------------------+
| Grants for selena@%                                                 |
+---------------------------------------------------------------------+
| GRANT USAGE ON *.* TO `selena`@`%`                                  |
| GRANT SELECT ON `gd`.`singers` TO `selena`@`%` WITH GRANT OPTION    |
+---------------------------------------------------------------------+
2 rows in set (0,009 sec)
```

```
MariaDB [gd]> show grants for pop_singers;
+---------------------------------------------------------------------+
| Grants for pop_singers                                              |
+---------------------------------------------------------------------+
| GRANT USAGE ON *.* TO `pop_singers`                                 |
| GRANT CREATE ON `world`.* TO `pop_singers`                          |
| GRANT SELECT ON `gd`.`singers` TO `pop_singers` WITH GRANT OPTION   |
+---------------------------------------------------------------------+
3 rows in set (0,000 sec)
```

IMPORTANTE!!!

RECORDERIS:

La instalación de MariaDB en los PC de las salas de la universidad se hicieron con el usuario root sin contraseña.

Esto está bien para propósitos académicos, pero nunca para usar en un sistema real o productivo.



PARA REFLEXIONAR (1)

Errores típicos en bases de datos de empresas pequeñas (y grandes también 🙂) en bases de datos reales en producción

- Usar "all privileges" en modo desesperación (si, pasa)
- Crear usuarios con % (pasa aún más seguido)
- Dar permisos con with grant option sin necesidad

PARA REFLEXIONAR (2)

Con las configuraciones no recomendadas, ¿cuanto tiempo puede pasar para perder el control de la base de datos?

(discusión verbal)

EJERCICIOS

DISCUSIÓN GRUPAL

Revisar la dirección ip de alguno de sus compañeros. Asegurarse que están en el mismo segmento de red.

Posteriormente crear una conexión hacia ese servidor con el usuario root, sin contraseña (de nuevo, esto es así por propósitos académicos, no hacerlo así en la vida real).

Una vez establecida la conexión, intentar realizar select sobre cualquier tabla de la base de datos world. ¿Qué sucede y porqué?

EJERCICIOS

Ejercicio 1

Usando los mismos usuarios y roles de la clase anterior, definir los siguientes permisos:

- Rol de desarrolladores:
  - insert, select sobre las tablas "cities" y "countries"
  - crear, modificar y eliminar rutinas
- Rol de analistas de pruebas:
  - insert, select, update, delete sobre las tablas "cities", "countries", "languages" y "countries_languages"
- Rol de analistas de negocio:
  - select sobre la instancia completa

EJERCICIOS

Ejercicio 2

Revisar la dirección ip actual y la máscara de red. Modificar los scripts de la clase anterior para crear los usuarios en la subred actual.

Posteriormente intentar crear una nueva conexión en el ide de su preferencia (en clases se está usando el mysql workbench), pero no con el usuario root sino con alguno de los usuarios recién creados.

Probar la conexión con los usuarios de la misma subred y con los que sólo tienen una ip específica. Validar que las conexiones se acepten o se denieguen.

EJERCICIOS

Ejercicio 3

Una vez validadas las conexiones del ejercicio anterior, intentar las operaciones de select, update, etc…, conectándose como un usuario desarrollador y como un analista de pruebas.

Validar que las operaciones sean admitidas o denegadas acorde a los permisos del rol.

EJERCICIOS

Ejercicio 4

En las salas de clase, intentar la conexión con un usuario desarrollador hacia el pc de alguno de sus compañeros y posteriormente probar operaciones de insert, update, delete o insert. Validar que las operaciones que se acepten o las que fallan sean acordes a lo definido en los privilegios.

NOTA: Es posible que algunos software antivirus en Windows o firewalls en Linux bloqueen las conexiones desde otro lugar.

¿PREGUNTAS?

